API 设计 — AI 辅助实验记录（任务 2.2）

> 对应文件：`API规范文档.md` | 实验日期：2026-05-17

实验流程

1. 向 AI 提供 P1 需求规格说明书 + P2 架构设计文档 + P3 类图，让其生成完整的 RESTful API 文档
2. 团队对照以下 4 个维度逐条审查 AI 输出
3. 记录问题并修正，形成最终的 `API规范文档.md`

审查结果

维度 1：接口命名不一致

问题	AI 原始输出	修正
URL 单复数混用	`/api/user/me` 与 `/api/users/{id}` 并存	统一为复数 `/api/users/me`、`/api/users/{id}`
动作命名风格不一致	`cancelDemand` 使用 RPC 风格路径 `/api/demands/cancel`	统一 RESTful：`DELETE /api/demands/{id}`
资源嵌套层级不一	部分接口将子资源平铺（如 `/api/reviews?orderId=1`），部分嵌套（如 `/api/orders/{id}/reviews`）	统一为嵌套风格（子资源挂载在父资源路径下）

审查结论：AI 生成的 API 路径在 RESTful 风格上缺乏一致性，需人工统一规范后再定稿。

维度 2：缺少错误处理

问题	AI 原始输出	修正
只定义成功响应	所有接口仅有 200 成功示例	为每个接口补充至少 1 个失败响应 JSON 示例
无统一错误码	错误信息散落在各接口描述中，格式不统一	建立 6 类分段错误码体系（40000-50000），共 16 个错误码
遗漏业务冲突场景	未考虑并发接单冲突（40901）、重复评价（40903）等	补充 40900 业务冲突错误码段

问题	AI 原始输出	修正
遗漏认证/授权失败	未区分"未登录"(40100) 和"权限不足"(40300) 两种场景	分别定义 401xx 和 403xx 错误码

审查结论：AI 系统性遗漏了异常路径，只覆盖了"快乐路径"（happy path）。错误处理是 AI 生成 API 文档的最大盲区。

维度 3：参数校验不完整

问题	AI 原始输出	修正
必填/可选未标注	参数表缺少"是否必填"列	统一增加必填列，标注条件必填规则
字符串约束缺失	username、password 等字段未限制长度	补充：username 4-20 位、password 6-32 位、title 2-50 字、description 10-500 字
枚举值未说明	category 字段只写了类型 String，未列有效值	明确列出 `ERRAND / SKILL / STUDY / SECONDHAND`
板块特有校验遗漏	未体现 4 种板块的不同校验规则（如二手必须传图）	在"发布需求"接口中补充板块额外校验说明
分页参数未定义	列表接口缺少 page/size 默认值说明	统一分页规范（page 默认 0，size 默认 20）

审查结论：AI 倾向于"宽松定义"，缺乏从业务规则反推参数约束的意识。参数校验规则主要依赖人工从 SRS 中提取补充。

维度 4：安全问题

问题	AI 原始输出	修正
未标注认证要求	接口描述中未区分是否需要携带 JWT	每个接口以 `> 需认证` / `> 无需认证` 明确标注
敏感字段未脱敏	响应示例中 phone、email 返回完整值	响应示例中展示脱敏格式（`138****8000`），并增加脱敏规则说明
隐私可见性规则缺失	未体现"接单后对方手机可见、完成后隐藏"的业务规则	在订单详情接口中增加注释说明隐私信息的动态可见性
生产环境 Swagger 未提及	—	ADR-006 已有规定，API 文档中重申上线前关闭 Swagger UI

审查结论：AI 在安全意识上薄弱，不会自动对敏感字段做脱敏处理，也不会主动标注鉴权要求。安全相关的设计约束必须人工注入。

审查统计

维度	发现问题数	严重程度
接口命名不一致	3	中
缺少错误处理	4	**高**
参数校验不完整	5	**高**
安全问题	4	**高**
合计	**16**	

总结

- AI 可以快速生成 API 文档骨架和正向流程示例，节省约 **60%** 的机械性编写工作
- 但 AI 在**异常路径、业务约束、安全防护**三方面有系统性盲区，必须人工逐项审查后补全
- 建议后续 API 开发遵循 **"AI 生成骨架 → 团队逐项审查 → 人工补全边界条件"** 的三步流程